

HiveForce Labs

THREAT ADVISORY



VULNERABILITY REPORT

WordPress plugin has been exploited in the wild to mount backdoors

Date of Publication

December 29, 2022

Admiralty Code

A1

TA Number

TA2022323

Summary

First Seen: November 22, 2022

Affected Product: A WordPress plugin named Yith WooCommerce Gift Cards Premium

Impact: An unauthenticated attacker can implant a backdoor, gain Remote Code Execution, and seize control of the site.

CVE

CVE	NAME	PATCH
CVE-2022-45359	Unauthenticated Arbitrary File Upload vulnerability	

Vulnerability Details

Malicious actors are actively exploiting a critical vulnerability in the YITH WooCommerce Gift Cards Premium WordPress plugin in order to plant backdoors on e-Commerce sites. The security flaw (CVE-2022-45359) exists due to the "import actions from settings panel" function, which runs on the "admin init" hook. Additionally, this function does not perform capability and CSRF checks, allowing unauthenticated attackers to upload files to vulnerable sites, including web shells that provide full site access. Over 50,000 websites continue to use vulnerable versions of the plugin, enabling threat actors to exploit the bug and plant a backdoor to perform remote code execution attacks.

Vulnerability

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-45359	YITH WooCommerce Gift Cards Premium: upto 3.19.0	cpe:2.3:a:yithemes:yith_woocommerce_gift_cards:*:*:*:*:premium:wordpress:*:*	CWE-434

Recommendations



Security Leaders

Asset and vulnerability management solutions should be implemented to ensure that all internet-accessible devices are secure, patched, updated, hardened, and monitored. Integrate and communicate all lessons learned.



Security Engineers

- **Uni5 Users:** This is an actionable threat advisory in HivePro Uni5. Prioritize the vulnerability, identify the impacted assets, and patch them through your Command Center. Test your controls with Uni5's Breach & Attack Simulation.
- **All Engineers:** Refer to and action upon the 'Potential MITRE ATT&CK TTPs' & 'Patch Link' on the following pages.



Potential MITRE ATT&CK TTPs

<u>TA0042</u> Resource Development	<u>TA0040</u> Impact	<u>TA0001</u> Initial Access	<u>TA0004</u> Privilege Escalation
<u>T1548</u> Abuse Elevation Control Mechanism	<u>T1543</u> Create or Modify System Process	<u>T1588</u> Obtain Capabilities	<u>T1588.006</u> Vulnerabilities
<u>T1210</u> Exploitation of Remote Services	<u>T1584</u> Compromise Infrastructure	<u>T1565</u> Data Manipulation	<u>T1190</u> Exploit Public-Facing Application



Indicator of Compromise (IOCs)

TYPE	VALUE
Domain	shell[.]prinsh[.]com
IP Addresses	103[.]138[.]108[.]15 188[.]66[.]0[.]135

TYPE	VALUE
SH256	1a3babb9ac0a199289262b6acf680fb3185d432ed1e6b71f339074047078b28c3c2c9d07da5f40a22de1c32bc8088e941cea7215cbcd6e1e901c6a3f7a6f9f198cc74f5fa8847ba70c8691eb5fdf8b6879593459cfd2d4773251388618cac90d

🔗 Patch Link

<https://www.wordfence.com/blog/2022/12/psa-yith-woocommerce-gift-cards-premium-plugin-exploited-in-the-wild/>

🔗 References

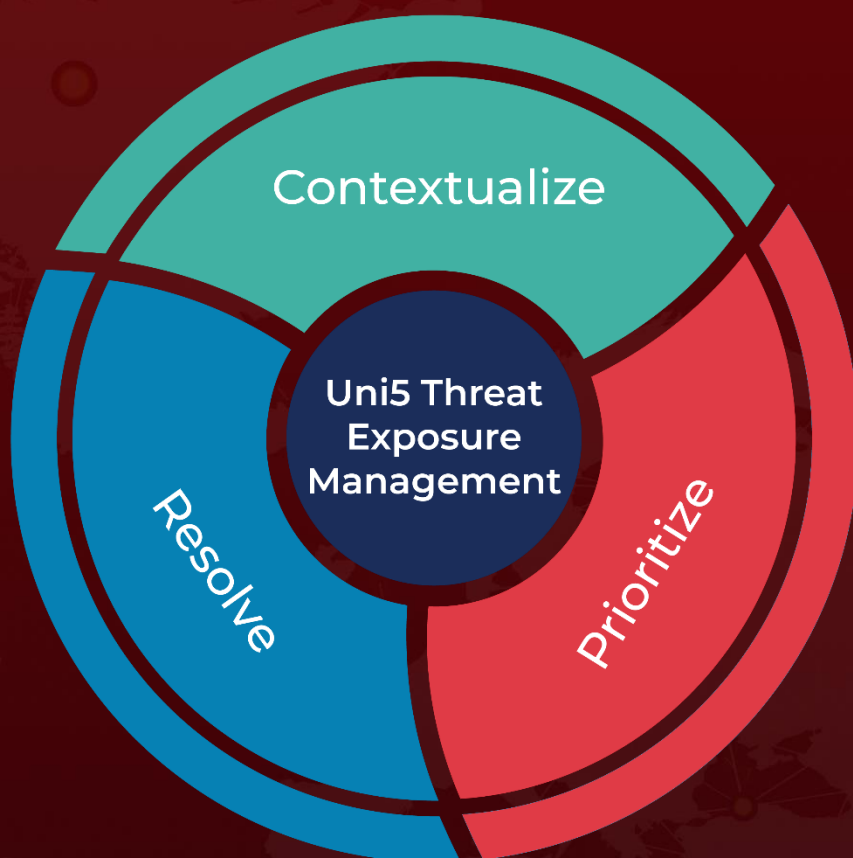
<https://www.wordfence.com/threat-intel/vulnerabilities/wordpress-plugins/yith-woocommerce-gift-cards-premium/yith-woocommerce-gift-cards-premium-3190-unauthenticated-arbitrary-file-upload>

<https://www.bleepingcomputer.com/news/security/hackers-exploit-bug-in-wordpress-gift-card-plugin-with-50k-installs/>

What Next?

At Hive Pro, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with HivePro Uni5: Threat Exposure Management Platform.



REPORT GENERATED ON

December 29, 2022 • 3:00 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com